Incident Management & Incident Response Handbook

1. Introduction to Security Incidents

What is a Security Incident?

A **security incident** is any confirmed event that threatens or compromises:

- **Confidentiality** – unauthorized disclosure of data
- **Integrity** – unauthorized modification of systems/data
- **Availability** – disruption of services or systems

Event vs Incident

Term	Definition
Event	Any observable occurrence (log entry, alert, anomaly)
Incident	An event that causes or may cause security impact

Example:

- Firewall log shows port scan → *Event*
- Same scan leads to system compromise → *Incident*

---

2. Types of Incidents

Security-Based Incidents: Malware, ransomware, phishing, social engineering, credential compromise, web application attacks (SQL injection, XSS, remote code execution), and unauthorized access.

Network-Based Incidents: Distributed denial-of-service (DDoS), man-in-the-middle attacks, port scanning, lateral movement, and command-and-control communications.

Endpoint / Host Incidents: Privilege escalation, rootkits, backdoors, suspicious processes, unauthorized file changes, and integrity violations.

Data Incidents: Data leakage, data exfiltration, accidental exposure through misconfigured storage or public shares.

Insider Incidents: Malicious insider activity, negligent user behavior, and policy violations.

---

3. Impact of Incidents

Business Impact: Revenue loss, Operational downtime, Customer churn, Contract/SLA violations

Technical Impact: System unavailability, Infrastructure compromise, Data corruption or loss

Legal & Regulatory Impact: Compliance penalties, Mandatory breach disclosures, Audit findings

Reputational Impact: Brand damage, Loss of stakeholder trust

---

4. Information Sources (Alerts, Logs, Network Flow)

Alerts: Generated by security platforms such as SIEM, EDR/XDR, IDS/IPS, firewalls, and cloud security tools. Alerts typically contain alert name, severity, timestamp, affected host or user, source and destination IPs, and a short description, and are used for early detection and investigation initiation.

Logs: Collected from systems, applications, authentication services, firewalls, proxies, databases, and cloud platforms. Logs provide time, user identity, IP address, performed action, and result status, and are primarily used for timeline reconstruction, root cause analysis, attribution, and compliance evidence.

Network Flow: Includes NetFlow, packet captures, and network telemetry. Network flow data reveals source and destination IPs, ports, protocols, session duration, and transferred bytes, and is used to detect command-and-control traffic, lateral movement, abnormal bandwidth usage, and data exfiltration.

---

5. Unauthorized Access Incidents

Definition: Any access to systems, networks, or data without explicit authorization or beyond granted privileges.

Common Causes: Phishing attacks, weak or reused passwords, credential stuffing, exploited vulnerabilities, and misconfigured access controls.

Key Indicators: Logins from unusual locations, impossible travel patterns, unexpected privilege escalation, creation of new administrator accounts, access outside business hours, and abnormal data downloads.

Response Actions: Disabling affected accounts, forcing password resets, reviewing authentication logs, identifying impacted systems, hunting for persistence mechanisms, conducting forensic analysis, and notifying stakeholders when required.

---

6. Key Components of an Incident Response Program

People: SOC analysts, incident responders, IT administrators, management, and legal or HR representatives responsible for coordinated response.

Process: Incident classification, severity mapping, escalation workflows, communication plans, standardized playbooks, and root cause analysis procedures.

Technology: SIEM, EDR/XDR, SOAR platforms, ticketing systems, threat intelligence feeds, and forensic tools.

Documentation: Incident tickets, evidence artifacts, investigation timelines, final reports, and lessons learned records.

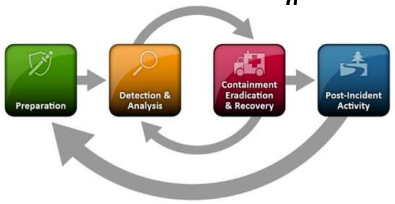
Metrics & Improvement: Mean time to detect (MTTD), mean time to respond (MTTR), incident volume, false-positive rate, repeat incident trends, and overall control effectiveness.

Incident Response Life Cycle

20 March 2025 21:43

As an incident handler, your daily activities will include discussing how an attacker attempted or managed to break into a system, in addition to preventing, detecting and responding to such attempts.

↳ Learn in details, about cyber kill chain.



Preparation: The Preparation phase of the incident handling process includes everything related to an organization's incident handling readiness.



↳ Incident handlers should have unrestricted and on demand access to systems.

① Security Awareness Training
② A skilled Team

① well defined policies
② Incident Communication plan
③ Well defined response plan
④ chain of custody

① AV, HIDS, DLP, EDR
② SIEM, UTM, Treat Intelligence
③ Honeypots.

Incident Handling Starter Kit: Data Acquisition software | Read-only diagnostic software |Bootable Linux environment | HDs, Ethernet TAP, Cables,Laptop

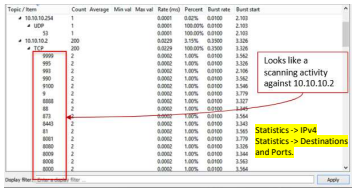
Detection & Analysis: The Detection & Analysis phase of the incident handling process includes everything related to detecting an incident.

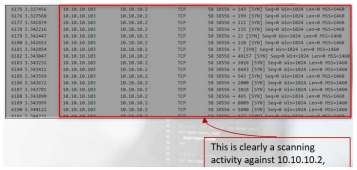
↳ Means of Detection (FW, IDS, Agents, Logs etc)
↳ Content about Threat Intelligence.
↳ Information and knowledge sharing.

An effective and actionable way to logically categorize your network is by considering the following levels:

Network Perimeter

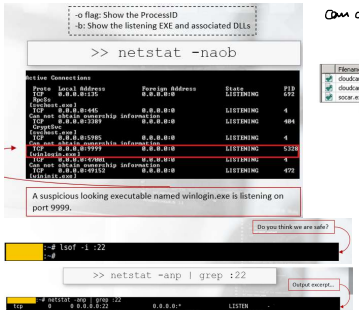
↳ Detection occurs at Network Level.
↳ Firewalls, DMZ, IPS, NIDS etc.





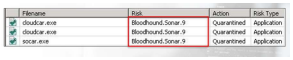
Host Perimeter

↳ Detection at host perimeter level occurs whenever we analyze data about packets found network or send out to Network



Host Level

↳ Detection happens when we analyze data residing in the host.
↳ AVs and EDR solutions, as well as the users themselves, can assist in such detection.

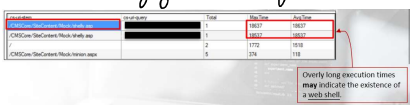


Application Level

↳ Detection at application level occurs whenever we analyze application logs.

Web application logs, service logs, etc. can assist in such detection activities since they offer valuable insight, such as user operations, user input, etc., all accompanied by the respective time they were executed/submitted.

↳ An analyst spotting abnormal behaviour when analyzing web server logs.







What happened here is that the Linux-based malware utilized a kernel-level rootkit to conceal the SSH daemon process in the kernel process table.

"**lsof**" scans the process table, this is why it missed the concealed process and the accompanying open sockets.
"**netstat**" on the other hand, focuses on the open socket list, and only if we instruct it (-p flag), it tries to locate the associated processes in the process table. Regardless of "netstat" finding associated processes or not, it will still output open sockets.

Take Reference from:
- lana.org
- https://www.speedguide.net/ports.php

Example: We see a packet trying to reach port 21 of a host, or we see a host listening on port 21. It could be FTP traffic if our organization includes such functionality or malicious traffic if it doesn't.

Logs:
- Azure logs → https://docs.microsoft.com/en-us/azure/security/azure-log-audit
- Apache logs → http://httpd.apache.org/docs/current/logs.html

The **Containment, Eradication & Recovery** phase of the incident handling process, includes everything related to:

- Preventing an incident from getting worse (i.e., preventing the intruder from getting any deeper) < Containment
- Eliminating intruder artifacts, understanding the root cause, attackvectors and TTPs in general, utilizing backups and improving < Eradication
- Restoring and monitoring to make sure nothing evaded detection < Recovery

Since we are now dealing with a declared incident, we need to classify it based on the information we analyzed, its possible impact, and its extent.

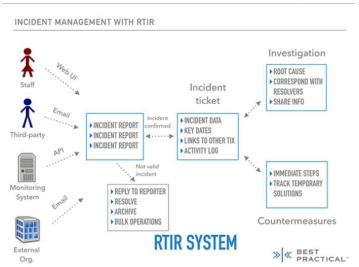






Before we even start the Containment process, we should be extremely careful not to let the attacker(s) know our operations; this means, no submitting of identified binaries to cloud A/V solutions and no interacting with any identified IP addresses just yet. Act Normally..

Before we even start the Containment process, we should be extremely careful not to let the attacker(s) know our operations; this means, no submitting of identified binaries to cloud A/V solutions and no interacting with any identified IP addresses just yet.



Containment is divided into the following subphases:

Short-term Containment

During this subphase, we should try to render the intrusion ineffective, without altering the machine's hard drive (we need to image it for forensic activities).

→ Disable Network Connectivity
→ Disconnect machine from the power like
→ Place machine in a separate VLAN.
→ Change DNS
→ Isolate through Firewall

System Back-up

To preserve the evidence, you're not supposed to work on the original machine when investigating and you're also not supposed to analyze and work on the first image you take.

The original image is usually verified (which we'll cover later) and then saved alongside other parameters to protect it from tampering, while all the work is done on copies of the original Image.

Order of Volatility:

The storage mediums can be arranged from the most volatile to the least, as follows:



Static Acquisition: process of Acquiring Non-Volatile Data.
↳ Performed on Hard Disk

Live Acquisition: Process of Acquiring Volatile Data
↳ Performed on RAM

Dead Acquisition: Process of Acquiring data from a powered off system by removing its Hard Drive and attaching it to forensic workstation.

Acquisition Approaches

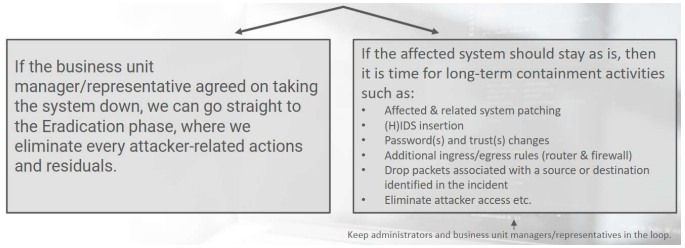
1. The first way is from disk drive to image file (imaging)

2. The second one is from disk drive to disk drive (cloning)

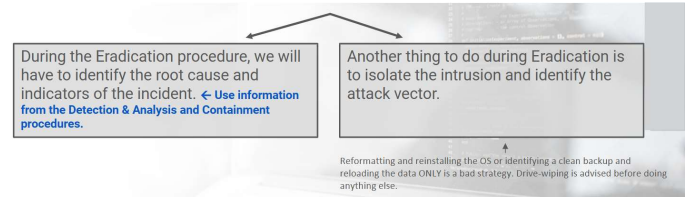
Long-term Containment

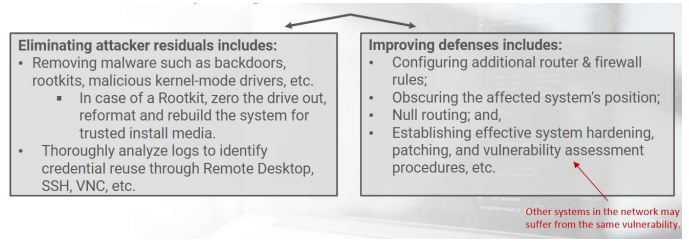
Before moving on to the Long-term Containment phase, communicating with your ISP may be needed, especially in cases of DDoS attacks, worms, or phishing campaigns; this is due to the fact that ISPs not only have greater visibility when it comes to attacks in the wild, but they also keep useful logs.

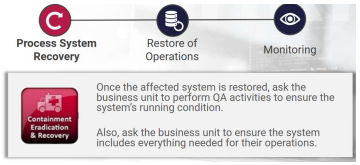
After the imaging and live acquisition activities are completed, we can start performing long-term containment activities.

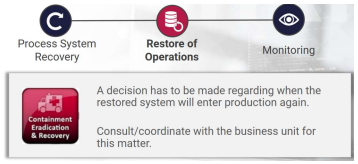


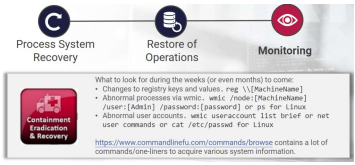
→ Eradication should take Place in order to make sure the attacker is locked out of the affected machine and network.











we have reached the **Post-incident Activity** phase, which is when we take a deep breath and report the identified weaknesses, oversights, blind spots, etc., regarding both our processes and technological measures.

This is not to say that the report should contain only the identified weaknesses, oversights, and blind spots. Working processes and successful detection methods should also be included. Don't be afraid to mention how effective you were against specific stages of the attack.

Schedule a meeting when things cool down to discuss this report with all involved parties, such as system administrators, affected business unit representatives, IT security team, etc. Focus your energy on improving your processes, technological measures and visibility.